

DPDP COMPLIANCE AUDIT

dpdp-agency

Digital Personal Data Protection Act 2023

52/100

Grade D

At Risk

Scanned: 25 March 2026

Files indexed: 130

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

This codebase has 2 critical compliance gap(s) that require immediate attention under the Digital Personal Data Protection Act 2023. An additional 6 significant gap(s) were identified that should be addressed within 30 days. The estimated total remediation effort is 3.4–12.2 engineering days.

Validation Summary Rule findings: 20 confirmed, 3 false positives suppressed • AI gaps: 0 dual-validated • Score: 52 (rules) → 52 (integrated)

Total findings: 20

HIGH: 2

MEDIUM: 6

INFO: 5

PASS: 5

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	0/22 (0%)	FAIL
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	0/18 (0%)	FAIL
Section 8	10	10/10 (100%)	PASS
Section 8(3)	8	4.0/8 (50%)	WARN
Section 8(4)	8	4.0/8 (50%)	WARN
Section 8(6)	8	8/8 (100%)	PASS
Section 9	6	6/6 (100%)	PASS
Section 11	6	6/6 (100%)	PASS
Section 16	4	2.0/4 (50%)	WARN
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal	4	4/4 (100%)	PASS

Estimated Total Remediation Effort: 3.4–12.2 engineering days

Data Flow Analysis

The following PII flow signals were inferred via static analysis (import/call adjacency). These are heuristic code-path chains, not proven runtime traces. Use them to guide developer review (confirm actual request → handler → service → database paths in your app).

Flow 1: Application Logs

PII fields: email, mobile, address
server.js

Flow 2: Application Logs

PII fields: email, mobile, address
server.js → db.js

Flow 3: Application Logs

PII fields: email, mobile, address
server.js → phishingRoutes.js → phishingMailer.js

Flow 4: Application Logs

PII fields: password, email

phishingRoutes.js → User.js → db.js

Flow 5: Application Logs

PII fields: email, password

phishingRoutes.js → phishingMailer.js

Rule	Section	Severity	File
AUDIT_TRAIL_PARTIAL	Section 8(4) — Audit Trail	MEDIUM	N/A
RETENTION_PARTIAL	Section 8(3) — Retention	MEDIUM	N/A
INCOMPLETE_DELETION_COVERAGE	Section 8 — Data Principal Rights	MEDIUM	N/A
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
CHILDRENS_DATA_PATTERN	Section 9 — Children's Data	LOW	frontend/src/pages/tools/GrievanceGenerator.jsx
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	backend/server.js
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	backend/src/routes/phishingRoutes.js
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	backend/src/utis/auditLogger.js
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A
NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
CONSENT_WITHDRAWAL_PRESENT	Section 6(6) — Consent Withdrawal	PASS	backend/src/readiness_checklist/schemas.js
DELETION_MECHANISM_PRESENT	Section 8 — Data Principal Rights	PASS	backend/src/routes/adminRoutes.js
BREACH_INDICATORS_ADEQUATE	Section 8(6) — Breach	PASS	N/A
DATA_ACCESS_PRESENT	Section 11 — Right to Access	PASS	frontend/src/context/AuthContext.jsx
GRIEVANCE_OFFICER_PRESENT	Section 13 — Grievance Redressal	PASS	backend/src/dpdp_generator/schemas.js
CONSENT_MISSING	Section 6 — Consent	HIGH	frontend/src/pages/PhishingEducation.jsx
PLAINTEXT_PII_IN_LOGS	Section 8(1) — Security	HIGH	backend/server.js
PASSWORD_NOT_HASHED	Section 8(1) — Security	MEDIUM	MULTIPLE
CROSS_BORDER_TRANSFER_RISK	Section 16 — Cross-Border Transfer	MEDIUM	backend/src/dpdp_generator/generator.js
RETENTION_MISSING	Section 8(3) — Retention	MEDIUM	MULTIPLE

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (3–11 hours)

Fix immediately — these represent the highest legal exposure.

- Consent Missing — pages/PhishingEducation.jsx (2–8 hrs)
- Plaintext Pii In Logs — backend/server.js (1–3 hrs)

Week 2 — High Priority (16–56 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Audit Trail Partial (2–8 hrs)
- Retention Partial (2–8 hrs)
- Incomplete Deletion Coverage (2–8 hrs)
- Password Not Hashed — MULTIPLE (2–5 hrs)
- Cross Border Transfer Risk — dpdp_generator/generator.js (4–12 hrs)
- Retention Missing — MULTIPLE (4–15 hrs)

Week 4 — Advisory (3–12 hours)

Address before next compliance review.

- Data Portability Missing (2–8 hrs)
- Childrens Data Pattern — tools/GrievanceGenerator.jsx (1–4 hrs)

Total estimated remediation effort: 22–79 hours (2.8–9.9 engineering days)

Details

Finding 1 of 20

[Section 8(4) — Audit Trail]

1. [MEDIUM] AUDIT_TRAIL_PARTIAL — N / A

Estimated fix time: 2–8 hours

Partial audit trail detected. Found: access logging. Missing: audit model, change tracking.

Risk:

While access logging is present, a comprehensive audit trail is missing, meaning critical events like data access, modification, or deletion may not be recorded, hindering accountability and the ability to investigate data breaches as required by the DPDP Act.

Fix:

1. Define a clear 'Audit' model that captures essential information for each auditable event (e.g., timestamp, user ID, action performed, data affected, IP address).
2. Implement middleware or service functions to automatically log relevant events to this Audit model whenever sensitive data is accessed, modified, or deleted.
3. Ensure that the audit trail is stored securely and is immutable to prevent tampering.
4. Integrate the audit logging into the existing logger configuration to centralize log management.

DPDP:

Section 8(4) — Audit Trail

Example:

```
const auditLogger = require('./src/config/auditLogger'); // Assuming a separate audit logger
// Example middleware to log data access app.use(async (req, res, next) => { // Log access to
sensitive data endpoints if (req.path.startsWith('/api/users') ||
req.path.startsWith('/api/data')) { await auditLogger.logAccess({ userId: req.user ?
req.user.id : 'anonymous', action: 'ACCESS', target: req.path, ipAddress: req.ip }); } next();
});
```

Finding 2 of 20

[Section 8(3) — Retention]

2. [MEDIUM] RETENTION_PARTIAL — N / A:14**Evidence snippet:** Initializes associations for models, indicating relationships between them.**Estimated fix time:** 2–8 hours

Retention signals found in 1 model(s) but 4 PII model(s) have no retention policy. Uncovered: AuditLog.js, PhishingSimulation.js, Submission.js.

Risk:

The absence of a defined data retention policy means personal data could be stored indefinitely, increasing the risk of unauthorized access or misuse and violating DPDP requirements for data minimization and purpose limitation.

Fix:

1. Define a clear data retention policy for all PII models (e.g., User, Submission, CompanyRiskProfile, Vendor, PhishingCampaign).
2. Implement a mechanism to automatically delete or anonymize data that has exceeded its retention period. This could involve scheduled jobs or lifecycle policies.
3. Update the `backend/src/dpdp\_generator/generator.js` to dynamically include or exclude the retention section based on the actual data retention policies configured for the specific data being processed.
4. Add logging to track data deletion or anonymization activities for audit purposes.

DPDP:

Section 8(3) — Retention: Personal data shall not be kept in an identifiable form for longer than is necessary for the purposes for which the personal data are processed.

Example:

```
class User extends Model { static #retentionPeriod = '1 year'; // Example retention period }  
// In a data management service: async function cleanupOldData() { const cutoffDate = new  
Date(); cutoffDate.setFullYear(cutoffDate.getFullYear() - parseInt(User.#retentionPeriod)); //  
Simplified calculation await User.destroy({ where: { createdAt: { [Op.lt]: cutoffDate } } });  
logger.info('Old user data cleaned up.');
```

Finding 3 of 20

[Section 8 — Data Principal Rights]

3. [MEDIUM] INCOMPLETE_DELETION_COVERAGE — N / A**Estimated fix time:** 2–8 hours

Deletion mechanism detected but may not cover all PII storage. Uncovered files: backend/src/config/db.js, backend/src/models/AuditLog.js, backend/src/models/CompanyRiskProfile.js, backend/src/models/Course.js, backend/src/models/Module.js. DPDP Section 8 requires complete erasure of all personal data across all systems when a user requests deletion.

Risk:

Incomplete deletion coverage means that when a data subject requests erasure, not all their personal data might be removed, leading to continued processing and potential non-compliance with the DPDP's right to erasure.

Fix:

1. Implement a comprehensive 'delete user' or 'anonymize data' endpoint that triggers deletion across all relevant models (User, Submission, CompanyRiskProfile, Vendor, PhishingCampaign, AuditLog, Course, Module).
2. Ensure that the deletion logic in `backend/src/config/db.js` or related data access layers correctly handles cascading deletes or explicitly removes data from all associated tables.
3. For models like `AuditLog.js`, consider implementing data purging strategies based on retention policies rather than immediate deletion if logs are critical for compliance.
4. Add a mechanism to verify that all PII associated with a user has been deleted or anonymized, potentially through a separate audit process.

DPDP:

Section 8 — Data Principal Rights: This section outlines the rights of data principals, including the right to erasure, which requires complete deletion of personal data.

Example:

```
async function deleteUserAndRelatedData(userId) { // Example for User model, extend to other
PII models await User.destroy({ where: { id: userId } }); await Submission.destroy({ where: {
userId: userId } }); await CompanyRiskProfile.destroy({ where: { userId: userId } }); // ...
add calls for other models like Vendor, PhishingCampaign, AuditLog, etc. logger.info(`User
${userId} and associated data deleted.`); }
```

Finding 4 of 20

[Section 11 — Data Portability]

4. [LOW] DATA_PORTABILITY_MISSING — N / A:74

Evidence snippet: Registers various API routes ('auth', 'company', 'training', 'phishing', 'admin', 'public', 'tool'), but no route explicitly for data export or portability.

Estimated fix time: 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Risk:

The absence of a data export or portability feature means users cannot exercise their right to receive their personal data in a structured, commonly used, and machine-readable format as required by DPDP Section 11.

Fix:

1. Create a new API endpoint (e.g., `/api/data-export/:userId`) that retrieves user's personal data from the database.
2. Implement logic to format the retrieved data into a machine-readable format (e.g., JSON or CSV).
3. Add a mechanism for users to request their data, potentially via a profile settings page or a dedicated support request.
4. Ensure the export endpoint is secured and accessible only by the authenticated user or authorized personnel.

DPDP:

Section 11(1) — Data Fiduciaries shall, upon request by the Data Principal, provide the personal data in a structured, commonly used and machine-readable format.

Example:

```
app.get('/api/data-export/:userId', async (req, res) => { const userId = req.params.userId;
try { // Fetch user data and related PII from database const userData = await
User.findByPk(userId, { include: [Submission, CompanyRiskProfile] }); // Example if
(!userData) return res.status(404).json({ message: 'User not found' }); // Format data to JSON
const dataToExport = userData.toJSON(); res.setHeader('Content-Disposition', 'attachment;
filename="user_data.json"); res.setHeader('Content-Type', 'application/json');
res.status(200).send(JSON.stringify(dataToExport, null, 2)); } catch (error) {
res.status(500).json({ message: 'Error exporting data', error: error.message }); } });
```

Finding 5 of 20

[Section 9 — Children's Data]

5. [LOW] CHILDRENS_DATA_PATTERN — frontend / src / pages / tools / GrievanceGenerator.jsx:11**Evidence snippet:** Defines STEPS for the Stepper component.**Estimated fix time:** 1–4 hours

Child/minor/student term paired with PII collection in same file. Requires human validation.

Risk:

The file uses terms like 'child' in the context of generating grievances, which, when paired with potential PII collection (even if not explicitly detailed in this snippet), could indicate processing of children's data without appropriate safeguards. This requires careful review to ensure compliance with DPDP Section 9.

Fix:

1. Review the 'formData' state and any data sent to the backend to ensure no PII of children is collected unless strictly necessary and with verifiable parental consent.
2. If children's data is processed, implement age verification mechanisms and obtain explicit parental consent.
3. Add clear privacy notices on this tool's interface explaining what data is collected and why, especially concerning minors.
4. Consult DPDP Section 9 guidelines for specific requirements on processing children's data, including data minimization and purpose limitation.

DPDP:

Section 9(1) — Data Fiduciaries shall not process the personal data of a child in contravention of the provisions of this Act and any rules made thereunder.

Example:

```
const [formData, setFormData] = useState({ organization_name: '', // Ensure no PII of children is collected without consent // If 'child_name' or similar fields are added, implement consent mechanisms grievance_officer: { name: '', designation: '', email: '', address: '' }, response_timeline_days: 30, escalation_available: true, language: ['en'] });
```

Finding 6 of 20

[Section 7 — Legitimate Use]

6. [INFO] INTERNAL_ROUTE_PII_ACCESS — backend / server.js

Internal file (server.js) accesses PII. Verify access is restricted to authorised contexts and PII is not exposed to logs or error responses.

Finding 7 of 20

[Section 7 — Legitimate Use]

7. [INFO] INTERNAL_ROUTE_PII_ACCESS — backend / src / routes / phishingRoutes.js

Internal file (phishingRoutes.js) accesses PII. Verify access is restricted to authorised contexts and PII is not exposed to logs or error responses.

Finding 8 of 20

[Section 7 — Legitimate Use]

8. [INFO] INTERNAL_ROUTE_PII_ACCESS — backend / src / utils / auditLogger.js

Internal dashboard/admin route accesses PII. Verify: (1) access is restricted to authorised staff only via role-based middleware, (2) a Section 7 legitimate use basis is documented in your compliance register.

Finding 9 of 20

[Section 5 — Notice]

9. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 10 of 20

[Section 5 — Purpose Limitation]

10. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 11 of 20

[Section 6(6) — Consent Withdrawal]

11. [PASS] CONSENT_WITHDRAWAL_PRESENT — backend / src / readiness_checklist / schemas.js

Consent withdrawal mechanism detected. Found in:
backend/src/readiness_checklist/schemas.js (line 17)

Finding 12 of 20

[Section 8 — Data Principal Rights]

12. [PASS] DELETION_MECHANISM_PRESENT — backend / src / routes / adminRoutes.js

Data deletion mechanism detected. Found 6 deletion endpoint(s) and 19 deletion signal(s).
Cascade delete patterns detected.

Finding 13 of 20

[Section 8(6) — Breach]

13. [PASS] BREACH_INDICATORS_ADEQUATE — N / A

Logging and/or breach alerting present.

Finding 14 of 20

[Section 11 — Right to Access]

14. [PASS] DATA_ACCESS_PRESENT — frontend / src / context / AuthContext.jsx

Data access endpoint detected for authenticated users.

Finding 15 of 20

[Section 13 — Grievance Redressal]

15. [PASS] GRIEVANCE_OFFICER_PRESENT — backend / src / dpdp_generator / schemas.js

Grievance redressal signal meets stricter checks (dedicated route, officer/DPO-style text, contact email). Consistent with Section 13 intent.

Finding 16 of 20

[Section 6 — Consent]

16. [HIGH] CONSENT_MISSING — frontend / src / pages / PhishingEducation.jsx:41**Evidence snippet:** Check the sender address carefully. Does it match the official domain?**Estimated fix time:** 2–8 hours

Personal data collection and API endpoint detected with no consent mechanism.

Risk:

The application collects or displays personal data (sender address) without obtaining explicit user consent, violating the DPDP Act's requirements for lawful data processing.

Fix:

1. Implement a consent banner or modal before displaying educational content that mentions personal data, explaining the purpose and obtaining user agreement.
2. If the 'sender address' is part of a simulation and not actual user data, clarify this in the UI to avoid misinterpretation.
3. Review the API endpoint mentioned in the rule engine evidence (Line 10) to ensure any data processed there also has a consent mechanism if it involves personal data.

DPDP:

Section 6 — Consent

Example:

```
import React, { useEffect, useState } from 'react'; import { useSearchParams, Link } from
'react-router-dom'; import Button from '../components/Button'; import SEO from
'../components/SEO'; import ConsentBanner from '../components/ConsentBanner'; // Assuming a
ConsentBanner component exists const PhishingEducation = () => { const [consentGiven,
setConsentGiven] = useState(false); const [searchParams] = useSearchParams(); const campaignId
= searchParams.get('campaign'); const handleConsent = (accepted) => {
setConsentGiven(accepted); }; if (!consentGiven) { return <ConsentBanner
onConsent={handleConsent} /> } return ( <> <SEO title="Phishing Awareness Education"
description="Learn to identify and protect against phishing attacks with interactive education
on common tactics and best practices." /> <div className="min-h-screen pt-20 md:pt-24 pb-12
px-4 max-w-7xl mx-auto flex flex-col items-center justify-center text-center"> <motion.div
initial={{ scale: 0.9, opacity: 0 }} animate={{ scale: 1, opacity: 1 }} className="glass p-12
rounded-2xl max-w-2xl w-full border border-red-500/30 relative overflow-hidden" > <div
className="absolute top-0 left-0 w-full h-1 bg-gradient-to-r from-red-500 to-orange-500" />
<div className="w-20 h-20 bg-red-500/20 rounded-full flex items-center justify-center mx-auto
mb-6 text-red-500 border border-red-500/30"> <ShieldAlert className="w-10 h-10" /> </div> <h1
className="text-3xl font-bold text-white mb-4">You just clicked a phishing link!</h1> <p
className="text-neutral-soft text-lg mb-8 leading-relaxed"> Don't panic! This was a simulation
sent by your security team. No data was compromised. However, if this had been a real attack,
your credentials could have been stolen. </p> <div className="bg-black/40 p-6 rounded-xl
border border-white/5 text-left mb-8"> <h3 className="text-white font-bold mb-4 flex
items-center gap-2 text-lg"> <AlertTriangle className="w-5 h-5 text-yellow-400" /> What to
look for next time: </h3> <ul className="space-y-4 text-neutral-light text-sm"> <li
className="flex items-start gap-3"> <span className="bg-red-500/20 text-red-400 font-bold px-2
rounded">1</span> Check the sender address carefully. Does it match the official domain? </li>
<li className="flex items-start gap-3"> <span className="bg-red-5
```

Finding 17 of 20

[Section 8(1) — Security]

17. [HIGH] PLAINTEXT_PII_IN_LOGS — backend / server.js:183**Evidence snippet:** logger.info('Email sent successfully from \${email}');**Estimated fix time:** 1–3 hours

PII keyword appears in logging call. Personal data may be written to logs in plaintext.

Risk:

Personal Identifiable Information (PII) may be logged in plaintext if the 'origin' string contains sensitive data, violating the security requirements of the DPDP Act.

Fix:

1. Sanitize or anonymize the 'origin' variable before logging it to prevent PII leakage.
2. Implement a more robust logging strategy that categorizes log data and restricts PII from being written to general access logs.
3. Review other logging statements in the application to ensure no other PII is inadvertently logged.

DPDP:

Section 8(1) — Security

Example:

```
const msg = 'The CORS policy for this site does not allow access from the specified Origin.';
// Sanitize origin before logging to prevent PII leakage
const sanitizedOrigin = origin ?
origin.replace(/^[a-zA-Z0-9.-]/g, '_') : 'unknown';
logger.warn(`CORS blocked origin: ${sanitizedOrigin}`);
callback(new Error(msg));
}, methods: ['GET', 'POST', 'PUT', 'DELETE', 'OPTIONS'], // Specify allowed methods
}); // Trust Proxy for Rate Limiting (Required if behind Nginx/Load Balancer)
app.set('trust proxy', 1); // 3. Body Parsers
app.use(express.json({ limit: '10mb' })); // Increased limit for potential larger payloads
app.use(express.urlencoded({ extended: true, limit: '10mb' }));
```

Finding 18 of 20

[Section 8(1) — Security]

18. [MEDIUM] PASSWORD_NOT_HASHED — MULTIPLE

Estimated fix time: 2–5 hours

Affected files (3):

- backend/src/models/associations.js
- backend/src/models/PhishingSimulation.js
- backend/src/models/User.js

Model file has password field but no hash/bcrypt/argon/pbkdf2/scrypt/encrypt reference.

Detected in 3 files: associations.js, PhishingSimulation.js, User.js

Risk:

Storing passwords in plaintext or without adequate hashing mechanisms poses a severe security risk, making user accounts vulnerable to unauthorized access if the database is compromised, violating the DPDP Act's security obligations.

Fix:

1. Implement password hashing using a strong algorithm like bcrypt or Argon2 before saving user credentials to the database. This should be done in the user registration and password update logic.
2. Ensure that any API endpoints or services that handle password storage or updates correctly integrate the hashing mechanism.
3. Add a check in the User model's save/update hooks or a pre-save middleware to automatically hash passwords if they are modified.

DPDP:

Section 8(1) — Security

Example:

```
const bcrypt = require('bcryptjs'); // Assuming 'User' is your Sequelize model
User.beforeCreate(async (user) => { if (user.password) { const salt = await
bcrypt.genSalt(10); user.password = await bcrypt.hash(user.password, salt); } });
User.beforeUpdate(async (user) => { if (user.changed('password') && user.password) { const
salt = await bcrypt.genSalt(10); user.password = await bcrypt.hash(user.password, salt); } });
```

Finding 19 of 20

[Section 16 — Cross-Border Transfer]

19. [MEDIUM] CROSS_BORDER_TRANSFER_RISK — backend / src / dpdp_generator / generator.js:108

Evidence snippet:

Estimated fix time: 4–12 hours

Foreign cloud storage/CDN detected with PII models in repo. Cross-border transfer risk.

Risk:

The code suggests that cross-border data transfer is a consideration, but the rule indicates a lack of explicit controls or assessments for such transfers, potentially leading to non-compliance with DPDP requirements for safeguarding data when transferred internationally.

Fix:

1. Identify all services or third-party tools used by the application that might process or store PII outside the user's jurisdiction.
2. For each identified cross-border transfer, assess the legal basis (e.g., adequacy decision, Standard Contractual Clauses, Binding Corporate Rules) and ensure appropriate safeguards are in place.
3. Update the `backend/src/dpdp\_generator/generator.js` to dynamically generate content for the `cross\_border.hbs` template based on the specific transfer mechanisms and safeguards in place for the data being processed.
4. Document all cross-border data transfer activities, including the purpose, data transferred, recipients, and the legal basis for the transfer.

DPDP:

Section 16 — Cross-Border Transfer: This section governs the transfer of personal data outside the jurisdiction, requiring specific conditions and safeguards to be met.

Example:

```
// Example of how to dynamically populate cross_border.hbs data async function
generateNotice(data) { // ... other logic ... const context = { ...input, crossBorderTransfer:
{ isEnabled: process.env.ENABLE_CROSS_BORDER_TRANSFERS === 'true', safeguards:
process.env.CROSS_BORDER_SAFEGUARDS || 'SCCs' } }; // ... render logic ... }
```

Finding 20 of 20

[Section 8(3) — Retention]

20. [MEDIUM] RETENTION_MISSING — MULTIPLE:20

Evidence snippet: Reads a 'retention.hbs' template, indicating that retention policies are a component of generated privacy notices.

Estimated fix time: 4–15 hours

Affected files (4):

- backend/src/models/AuditLog.js
- backend/src/models/PhishingSimulation.js
- backend/src/models/Submission.js
- backend/src/models/User.js

Model/schema file contains PII fields but no retention or expiry signals detected. Detected in 4 files: AuditLog.js, PhishingSimulation.js, Submission.js, User.js

Risk:

The absence of a defined data retention policy means personal data could be stored indefinitely, increasing the risk of unauthorized access or misuse and violating DPDP requirements for data minimization and purpose limitation.

Fix:

1. Define a clear data retention policy for all PII models (e.g., User, Submission, CompanyRiskProfile, Vendor, PhishingCampaign).
2. Implement a mechanism to automatically delete or anonymize data that has exceeded its retention period. This could involve scheduled jobs or lifecycle policies.
3. Update the `backend/src/dpdp\_generator/generator.js` to dynamically include or exclude the retention section based on the actual data retention policies configured for the specific data being processed.
4. Add logging to track data deletion or anonymization activities for audit purposes.

DPDP:

Section 8(3) — Retention: Personal data shall not be kept in an identifiable form for longer than is necessary for the purposes for which the personal data are processed.

Example:

```
class User extends Model { static #retentionPeriod = '1 year'; // Example retention period }  
// In a data management service: async function cleanupOldData() { const cutoffDate = new  
Date(); cutoffDate.setFullYear(cutoffDate.getFullYear() - parseInt(User.#retentionPeriod)); //  
Simplified calculation await User.destroy({ where: { createdAt: { [Op.lt]: cutoffDate } } });  
logger.info('Old user data cleaned up.');
```

Deep Compliance Review

Overall Risk: CRITICAL

Our recent code review reveals critical DPDP compliance risks stemming from inadequate technical safeguards, insufficient logging and auditability, and issues with transparency and consent for PII processing. These vulnerabilities are present across multiple architectural layers, creating a high likelihood of data breaches and significant regulatory non-compliance. Immediate action is required to fortify our data protection posture and ensure accountability.

Estimated remediation: 40 engineering day(s)

Most Critical Action: Implement and enforce secure database SSL/TLS configurations to protect all personal data in transit and at rest.

Layer Breakdown

Data Models & Storage — 3 finding(s). This layer defines data models and database connection. A critical security vulnerability was identified in the database SSL configuration, which directly undermines data protection. Additionally, gaps in transparency regarding data retention and the absence of database operation logging pose compliance risks related to accountability and data principal rights.

Third-Party & PII Flows — 3 finding(s). This layer presents significant DPDP compliance risks primarily due to misleading transparency statements regarding data processing, which can undermine consent. Additionally, the handling of sensitive PII in an unsandboxed iframe and during client-side PDF generation introduces security vulnerabilities that could lead to unauthorized access or exfiltration of personal data.

API Routes & Controllers — 4 finding(s). The API Routes & Controllers layer exhibits several DPDP compliance risks, primarily concerning the secure handling of PII in data flows (e.g., password reset links) and architectural patterns that could lead to unintended data processing or undermine accountability. Latent code for PII collection without consent and widespread exception swallowing also pose significant risks to data protection principles.

Authentication & Session — 4 finding(s). This layer contains critical security middleware for authentication, authorization, and general API protection. While foundational security controls are present, several configurations are explicitly relaxed for development and pose significant compliance risks if deployed to production, particularly regarding brute-force protection, CSP, and CSRF. Additionally, a minor issue in compliance document generation was identified.

Configuration & Secrets — 3 finding(s). The Configuration & Secrets layer exhibits critical DPDP compliance gaps primarily within its logging setup. The absence of log rotation and retention mechanisms, coupled with insufficient audit trail detail and unconditional console logging in production, poses significant risks to data minimization, security, and accountability. Addressing these issues is crucial for robust data protection.